



Figure 1: Top 5 network security scanners

used as a data provider. Due to its great GUI, any person with even some basic knowledge can use it.

Nmap: This is probably the only tool to remain popular for almost a decade. This scanner is capable of crafting packets and performing scans to a granular TCP level, such as SYN scan, ACK scan, etc. It has built-in signature-checking algorithms to guess the OS and version, based on network responses such as a TCP handshake. Nmap is effective enough to detect remote devices, and in most cases correctly identifies firewalls, routers, and their make and model. Network administrators can use NMAP to check which ports are open, and also if those ports can be exploited further in simulated attacks. The output is plain text and verbose; hence, this tool can be scripted to automate routine tasks and to grab evidence for an audit report.

Metasploit: Once sniffing and scanning is done using the above tools, it's time to go to the OS and application level. Metasploit is a fantastic, powerful open source framework that performs rigorous scans against a set of IP addresses. Unlike many other frameworks, it can also be used for anti-forensics. Expert programmers can write a piece of code exploiting a particular vulnerability, and test it with Metasploit to see if it gets detected. This process can be reversed technically—when a virus attacks using some unknown vulnerability, Metasploit can be used to test the patch for it. While this is a commercial tool, I have mentioned it here because the community edition is free, yet makes no compromises on the feature set.

OpenVAS: The Nessus scanner is a famous commercial utility, from which OpenVAS branched out a few years back to remain open source. Though Metasploit and OpenVAS are very similar, there is still a distinct difference. OpenVAS is split into two major components—a scanner and a manager. A scanner may reside on the target to be scanned and feed vulnerability findings to the manager. The manager collects inputs from multiple scanners and applies its own intelligence to create a report. In the security world, OpenVAS is believed to be very stable and reliable for detecting the latest security loopholes, and for providing reports and inputs to fix them. A built-in Greenbone security assistant provides a GUI dashboard to list all vulnerabilities and the impacted machines on the network. Creating detailed reports is one thing that makes OpenVAS a tool favoured by infrastructure security managers.

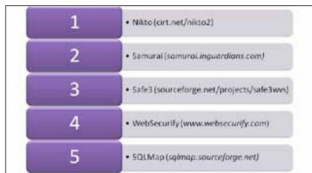


Figure 2: Top 5 web security scanners

Aircrack: The list of network scanners would be incomplete without wireless security scanners. Today's infrastructure contains wireless devices in the data centre as well as in corporate premises to facilitate mobile users. While having WPA-2 security is believed to be adequate for 802.11 WLAN standards, misconfiguration and the use of over-simple passwords leaves such networks open to attacks. Aircrack is a suite of software utilities that acts as a sniffer, packet crafter and packet decoder. A targeted wireless network is subjected to packet traffic to capture vital details about the underlying encryption. A decryptor is then used to brute-force the captured file, and find out passwords. Aircrack is capable of working on most Linux distros, but the one in Backtrack Linux is highly preferred.

The top five Web security assessment tools

Scanning websites is an entirely different ballgame from network scans. In the case of websites, the scope of the scan ranges from Layer 2 to 7, considering the intrusiveness of the latest vulnerabilities. The correct approach for scanning websites starts from Web-level access, right up to scanning all back-end components such as databases. While most Web security scanners are automated, there could be a need for manual scripting, based on the situation.

Nikto: Let's start with this tool because of its feature set. This open source tool is widely used to scan websites, mainly because it supports HTTP and HTTPS, and also provides findings in an interactive fashion. Nikto can crawl a website just the way a human would, and that too in the least amount of time. It uses a technique called mutation, whereby it creates combinations of various HTTP tests together to form an attack, based on the Web server configuration and the hosted code. Thus, it finds critical loopholes such as file upload misconfiguration, improper cookie handling, cross-scripting errors, etc. Nikto dumps all findings in a verbose mode, which helps in knowing more about the Web vulnerabilities, in detail. However, it can also result in too many things getting notified, some of which may be false alarms. Hence, care should be taken while interpreting Nikto logs.

Samurai framework: Once a baseline check is performed by Nikto, the next step is to take the 'deep-dive' approach. Samurai is a framework—a bunch of powerful utilities,